



Practica 2: PENTESTING: RECOPIACIÓN DE INFORMACIÓN

1. Introducción

La seguridad informática es una ilusión [5] pero aún si no es posible de garantizarla en su totalidad, no podemos simplemente resignarnos y dejar todo a la suerte. Un elemento esencial para poder tomar cartas en el asunto es saber cómo es que el atacante puede proceder, de qué herramientas dispondrá, qué datos le proporcionarán información que le ayudará a llevar a cabo el ataque y qué vulnerabilidades podría explotar.

El término pentesting se refiere a hacer pruebas atacando un sistema informático con la intención de encontrar sus vulnerabilidades ([1] pag. 223) Con frecuencia se utiliza como sinónimo de "hacking ético".

Objetivos

Generales

Conocer técnicas y herramientas empleadas para realizar pruebas de penetración y análisis de comunicaciones, mediante la programación de un script en bash. Con el objetivo de aprender a examinar dominios de internet y todo su segmento de red.

1.1. Particulares

Utilizar herramientas e análisis de segmentos de red como etherApe, nmap, ping, nslookup, traceroute, WHOIS, sublist3r, subfinder, dnsrecon, dnsmap, findomain, y paqueterías de Linux para el análisis de comunicaciones.

Requisitos

Conocimientos previos

Fundamentos en redes de computadores, sus componentes, topología y transmisión.

Tiempo de realización sugerido:

3 horas

Número de colaboradores:

2

software a utilizar

- VirtualBox (de preferencia, alternativas UTM o Parallels, o cualquier software de virtualización) con una máquina virtual de Kali Linux.
- ping
- nslookup
- traceroute
- WHOIS
- sublist3r
- subfinder
- findomain
- dnsmap
- dnsrecord
- Nmap
- EtherApe

planteamiento

El significado literal de pentesting es "pruebas de penetración". Se realiza por tanto un conjunto de ataques simulados, dirigidos a un sistema informático, con la finalidad de detectar posibles vulnerabilidades para que sean corregidas y no puedan ser explotadas por potenciales atacantes.

Las pruebas de penetración son como los caballeros medievales, que recorren el perímetro de su castillo, comprobando si hay grietas o cualquier punto débil que pueda permitir el acceso de los enemigos.

Existen varias fases en la realización de una prueba de penetración consensuadas por organismos que se dedican a la certificación, educación, capacitación y servicios de seguridad cibernética, como lo es EC-Council. Esta organización dividió las etapas que componen una auditoría de ciberseguridad en cinco pasos [2]

- Reconocimiento
- Escaneo
- Evaluación de vulnerabilidades
- Explotación
- Reporte

Las fases de reconocimiento y escaneo son la base para llevar a cabo una prueba de penetración. En la fase de recopilación, se recopila tanta información como se pueda sobre el sistema para que el evaluador pueda planificar una estrategia de ataque eficaz.

Una vez recopilados todos los datos, se puede comenzar con el escaneo. En esta etapa se utilizan varias herramientas para recolectar toda la información de nuestro objetivo haciendo uso de técnicas como:

- Escaneo de dominios/IP/puertos/versiones/servicios.

-
- Dorking que consiste en aprovechar herramientas de búsqueda como Google u Opera para encontrar información sensible.
 - Uso de herramientas automatizadas para obtener información
 - Obtención de metadatos.

Algunas de las herramientas más utilizadas en esta fase son de hecho las requeridas para llevar a cabo esta práctica. Herramientas como lo son: EtherApe, Nmap, ping, nslookup, traceroute, WHOIS, sublist3r, subfinder, dnsrecon, dnsmap, findomain, han sido favoritas por generaciones de hackers éticos que las encontraron realmente útiles para recabar información referente al objetivo que se pretende probar.

Usando Nmap se puede obtener el nombre del equipo, la dirección IP, el puerto con su respectivo servicio y estado. Una razón por la que NMap es muy útil es porque nos proporciona el servicio, si no se conoce qué servicio es no es posible planear una estrategia para vulnerarlo.

Un ejemplo de lo que se podría encontrar con NMap sería el puerto TCP 1720 cuyo servicio sería h323. El puerto TCP nos dice que este servicio usa el Protocolo de Control de Transmisión. TCP es un protocolo orientado en la conexión, necesita el apretón de manos para determinar comunicaciones de principio a fin. Solo cuando la conexión es determinada, los datos del usuario pueden ser mandados de modo bidireccional por la conexión. Ya siendo interesante esto, la información se vuelve más útil si conoces que el puerto pertenece al servicio h323.

El servicio h323 es el puerto más utilizado por Microsoft NetMeeting. Empleado para la configuración de llamadas de voz sobre IP. A este servicio se le encontró una falla la cual permite que un usuario remoto no autenticado bloquee el sistema, lo que provoca una denegación de servicio. La mayor amenaza de esta vulnerabilidad es la confidencialidad, la integridad y la disponibilidad del sistema. Este es sólo un ejemplo de por qué es útil saber cuál es el servicio asociado a cada puerto.

La información que se obtiene durante el proceso de recopilación de información es fundamental para definir los posibles vectores de ataque y explotación de sistemas. Cuanta más información y más valiosa, más probabilidades se tienen de conseguir pasar a las siguientes fases.

Esta fase del proceso debe ser hecha metódica y ordenadamente. Muchos hackers utilizan un modelo de datos inspirado en mapas mentales para dar una estructura de almacenamiento y tener todo disponible para posteriores consultas. También llevar a cabo un reporte es esencial para facilitar el acceso a la información.

En conclusión, esta práctica está enfocada principalmente en esta fase del pentesting donde darán a conocer y se usarán las herramientas más usadas por expertos, para introducir el concepto de auditoría de ciberseguridad.

desarrollo

Una vez instalados todos los requerimientos, se puede iniciar la práctica la cual consiste en recopilar información de los siguientes dominios:

- unam.mx
- pemex.com
- gob.mx
- ipn.mx
- pagina a elección

Utilizar comandos como ping para probar rápidamente los dominios listados, nslookup para saber si el DNS está resolviendo correctamente los nombres y las direcciones IP y WHOIS para determinar el propietario de un nombre de dominio o una dirección IP en Internet.

Utilizar también traceroute para mostrar posibles rutas y medir los retrasos de tránsito de los paquetes y findomain para enumerar los subdominios.

Findomain es una gran herramienta, pero no siempre numera todos los subdominios, por lo que es común complementar la información con otros motores de búsqueda. Uno de los más completos es sublist3r y subfinder. Usarlos también para complementar mediante sus datos de salida, la información obtenida.

Otras herramientas populares son dnsrecon y dnsmap, las cuales hacen un escaneo y como resultado se genera una enumeración DNS, de manera que permiten obtener información como enumeración de registros estándar para un dominio definido (A, NS, SOA y MX).

Analiza la información que obtienes con estos comandos por cada una de las direcciones utilizando estas herramientas. Se debe llevar a cabo un reporte y un script que realice esta tarea para que solo se tenga que analizar una vez cada dominio.

Usar Nmap [4] para sacar la mayor cantidad de información posible y datos sobre estas instituciones y con etherape [3] monitorear la propia red.

Gracias a la gráfica de etherape se puede observar todo el tráfico que se genera al momento de hacer estas peticiones. Utiliza esta herramienta para analizar el tráfico de la red.

insumos

Realizar un script que reciba de entrada un dominio como los listados a continuación:

- unam.mx
- pemex.mx
- gob.mx
- ipn.mx
- pagina a eleccion

También será capaz de recibir IPs.

Producto final

El script devolverá un texto plano en el cual se guardará la información relevante pre procesada para un análisis más sencillo. El texto plano contará como mínimo con los siguientes datos:

- Nombre del dominio.
- Cuando fue creado, actualizado y fecha de expiración.
- Nombre de la organización a la que pertenece y datos sobre esta (País, estado, ciudad, calle y código postal)
- Nombres del personal, email y teléfonos de contacto.
- Comprobar la conectividad de una red,
- Medir la latencia.
- La IP pública y sus segmentos.

-
- Registro de la disponibilidad.
 - Buscar registros IPv4 e IPv6.
 - Registros reversos.
 - La ruta y los saltos para llegar al dominio.
 - Enumerar las DNS
 - Puertos, estados y servicios.

Se deja al estudiante la libertad de agregar más información que crea relevante. En caso de agregarla, documentar y justificar el por qué es relevante en el reporte de la práctica.

Actividad

Analizar los datos dominio por dominio es una tarea larga y tediosa, por lo que se hará un script en bash que filtre la información relevante, de manera que solo sea necesario ejecutarlo una vez por cada dominio que fungirá como la entrada del script.

El script deberá guardar la información que el estudiante considere relevante en un archivo de texto que tendrá como nombre el dominio analizado. Los datos que se deberán desplegar de una manera que sea amigable y fácil de leer, de modo que facilite el análisis posterior.

Preguntas

1. Menciona los tipos de protocolos de red.
2. Respecto a la pregunta anterior. ¿Cómo funcionan? ¿Para qué sirven?
3. ¿Qué es un sniffer?
4. ¿Qué significa OSINT? ¿Para qué sirve?
5. Investiga los 5 OSINT más usados.
6. Investiga 5 softwares no mencionados en la práctica que sirvan para el análisis de comunicaciones.
7. ¿Por qué se considera a las personas como el eslabón más débil de seguridad?
8. ¿Qué acciones haces para protegerte de ciberataques?
9. ¿Crees que tus métodos preventivos son suficientes?

Entregables

Archivo en formato PDF con la realización detallada de la actividad, incluyendo las siguientes secciones:

- Requisitos: Se debe incluir todo lo que se necesita para obtener la información mediante la prueba de penetración. Por ejemplo ¿qué problema se quiere resolver o qué se quiere saber? ¿Qué información es necesaria para ello? ¿Para qué?
- Identificación de fuentes de información: ¿Qué fuentes pueden aportar información valiosa y veraz?

-
- Adquisición: Etapa de obtención de la información. Explicación del script.
 - Procesamiento: Dar formato a toda la información sin filtrar obtenida en la fase anterior. En caso de querer obtener más información explicar el posible uso de la misma, así como su relevancia.
 - Análisis: Generar datos de inteligencia a partir de todos los datos obtenidos, identificando relaciones estos que hagan y posibles vulnerabilidades. Se puede usar como referencia el ejemplo de la sección anterior.
 - Propuestas: Presentar propuestas de ataque formuladas por el alumno teniendo en cuenta lo hecho en el inciso anterior.

Se incluirá una sección de preguntas de refuerzo y una de referencias en formato APA. El carecer de referencias invalidará la práctica entera.

Referencias

- [1] Tony Campbell and Brent Beach. *Practical Information Security Management: A Complete Guide to Planning and Implementation*. Apress, New York, NY, 2016.
- [2] EC-Council. Learn about the five penetration testing phases, 2023. Accessed: 2024-05-22.
- [3] Riccardo Ghetta and EtherApe Contributors. EtherApe: A graphical network monitor. <https://etherape.sourceforge.io/>, 2026. Accedido: 17 de febrero de 2026.
- [4] Gordon Lyon. Nmap Download Page. <https://nmap.org/download.html>, 2026. Accedido: 17 de febrero de 2026.
- [5] Kevin D. Mitnick and William L. Simon. *The Art of Deception: Controlling the Human Element of Security*. Wiley, Indianapolis, IN, 6th edition, 2002.